

IMPACT ANALYSIS

CR-004: Student Input Validation and Strong Password Enforcement

1. Change Summary

CR-004 introduces comprehensive input validation for the administrator's student Add and Edit operations.

Administrators will be required to enter valid student information including registration number, first name, last name, email, and phone number. First and last names must contain at least 3 characters, and phone numbers must contain exactly 10 digits.

For new student accounts, a strong password policy will also be enforced. The password must contain at least 8 characters, including uppercase and lowercase letters, a number, and a special character.

Validation will be implemented on both the client side and server side to prevent invalid or insecure data from being stored.

2. Impact Assessment

Area	Impact	Assesment
Frontend	Moderate	Student Add/Edit form validation logic and validation messages will be added.
Backend	Moderate	Server-side validation will be added to prevent invalid API requests and validation bypass.
API	Low	Existing Student Add/Edit endpoints remain in use; request validation will be strengthened.
Database	None	No database schema changes are required.
Authentication	None	Existing authentication remains unchanged.
Authorization	None	Existing administrator authorization remains unchanged.
Security	Moderate	Strong password and server-side validation improve data and account security.
Performance	Low	Validation uses lightweight client-side and server-side checks.
CRUD	Low	Existing Add, Edit, and Delete operations must continue working correctly.
Deployment	Low	No database migration or new API endpoint is required.

3. Frontend Impact

The main affected area is the administrator's student Add/Edit form.

Potential changes include:

- Required field validation.
- Registration number validation.
- First name minimum 3-character validation.
- Last name minimum 3-character validation.
- Name character validation.
- Email format validation.
- Exactly 10-digit phone validation.
- Numeric-only phone input.
- Strong password validation for new students.
- Clear validation error messages.
- Prevention of invalid form submission.
- Appropriate input restrictions such as phone number length.

The implementation must provide clear feedback to administrators without affecting the existing student Add and Edit interface.

4. Backend, API and Database Impact

Backend validation will be added to the existing student Add and Edit operations.

The existing student API endpoints will continue to be used.

The backend must validate:

Server-side validation is required to prevent users from bypassing frontend validation by directly sending API requests.

- Registration number.
- First name.
- Last name.
- Email address.
- Phone number.
- Password when creating a new student.

No new API endpoint is required.

No database schema changes are required.

The existing parameterized database queries and password hashing mechanism must continue to be used.

5. Security Impact

The change provides a positive security impact because validation will be performed on both the frontend and backend.

The existing authentication and authorization mechanisms remain unchanged.

The validation feature must:

- Not bypass existing authentication.
- Not bypass administrator authorization.
- Reject invalid data at the server level.
- Prevent weak passwords when creating new student accounts.
- Ensure passwords are not stored as plain text.
- Continue using the existing secure password hashing mechanism.
- Not expose sensitive information through validation errors.
- Preserve existing backend security controls.

The strong password requirement improves protection against weak student account credentials.

6. CRUD and Functional Impact

Existing administrator CRUD operations must continue to work after validation is introduced.

Particular attention is required for:

- Adding a student with valid information.
- Rejecting a student with invalid information.
- Editing an existing student with valid information.
- Rejecting invalid information during editing.
- Maintaining the correct `student_id`.
- Preserving existing Delete functionality.

Validation must only control whether submitted data is valid. It must not change the identity of the student or the existing CRUD behaviour.

7. Performance Impact

The expected performance impact is low because the validation rules consist primarily of simple string, regular-expression, and length checks.

Client-side validation occurs before an API request is sent, which can prevent unnecessary requests containing invalid information.

Server-side validation adds only a small processing overhead before database operations.

No additional API request is required for validation.

The current implementation is suitable for the expected student dataset size.

8. Testing Impact

Manual and API testing should cover:

- Empty required fields.
- Registration number validation.
- First name with fewer than 3 characters.
- First name with 3 or more valid characters.
- Last name with fewer than 3 characters.
- Last name with 3 or more valid characters.
- Invalid characters in first name.
- Invalid characters in last name.
- Invalid email format.
- Valid email format.
- Phone number with fewer than 10 digits.
- Phone number with exactly 10 digits.
- Phone number with more than 10 digits.
- Non-numeric phone number.
- Empty password during student creation.
- Password shorter than 8 characters.
- Password without uppercase letters.
- Password without lowercase letters.
- Password without numbers.
- Password without special characters.
- Valid strong password.
- Valid student creation.
- Invalid student creation.
- Valid student update.
- Invalid student update.
- Direct API request containing invalid data.
- Existing Edit functionality.
- Existing Delete functionality.
- Administrator authentication and authorization.
- Password hashing and secure storage.

9. Risk Analysis

Risk	Impact	Mitigation
Invalid student data stored in database	High	Implement both frontend and backend validation.
Client-side validation bypass	High	Perform the same critical validation on the server.
Weak student passwords	High	Enforce minimum 8 characters, uppercase, lowercase, number, and special character.
Existing valid student data rejected incorrectly	Medium	Test validation rules with valid existing records.
Existing CRUD functionality breaks	High	Perform regression testing for Add, Edit, and Delete.
Phone number validation prevents valid input	Medium	Require exactly 10 numeric digits and test valid Sri Lankan phone formats.
User confusion caused by unclear errors	Medium	Provide clear field-specific validation messages.
Validation affects existing Edit operation	Medium	Test Edit with both valid and invalid data.
Password stored insecurely	High	Continue using the existing password hashing mechanism.
Minor performance overhead	Low	Use lightweight validation rules before database operations.

10. Overall Impact and Recommendation

Overall Impact: Moderate

CR-004 is primarily a frontend and backend validation enhancement. It requires changes to the student Add/Edit form and backend controller validation, but does not require database schema changes, new API endpoints, or changes to authentication and authorization.

The change will improve:

Student data quality.

Input consistency.

Account security.

Protection against invalid API requests.

Administrator user experience.

The change is technically feasible and recommended for implementation, subject to formal approval and subsequent testing.

Key implementation consideration: Critical validation must be performed on the backend as well as the frontend so that invalid or weak data cannot be submitted by bypassing the user interface.